

AdLoop Production Readiness Audit

Complete evidence-based, read-only audit | 19 August 2026 | English / LTR

VERDICT: NOT READY FOR PAID-CUSTOMER LAUNCH

Executive decision. Do not launch paid subscriptions or customer-facing ad-write actions until P1 findings are remediated and payment/provider validations are passed in sandbox. The codebase has strong defensive foundations, but payment and AI consumption boundaries are not production-safe under concurrency.

Executive Summary

Scope covered the complete checked-out Next.js 15 / Prisma SaaS: 133 API routes, schema, auth/tenant isolation, billing/Paymob webhooks, AI quotas, attribution/conversion sync, ad-platform write actions, e-commerce webhooks, cron jobs, configuration, deployment, documentation and localization. No project file, database, migration, credentials, provider account, payment or destructive test was modified.

Findings	P0	P1	P2	P3	External validation required
13 consolidated meaningful risks	0	5	5	3	4

Most realistic immediate incidents: duplicate Paymob checkout intents and possible double charging; access or AI credits granted for a valid callback not economically bound to the expected local intent; AI provider spend exceeding sold quota under parallel requests; stale reports/actions when one serial daily cron exceeds platform limits; and raw provider errors shown to customers during advertising changes.

Methodology and Boundaries

- End-to-end static flow tracing: session → workspace authorization → paid/provider action; checkout → Paymob callback → entitlement; AI request → quota → provider; conversion → platform upload; cron → reporting/automation.
- Safe checks executed: TypeScript `--noEmit --incremental false` passed; translation/key, webhook-auth, platform-call-counting and workspace-access scripts executed; offline production dependency audit found 0 known vulnerabilities.
- Not run: DB-mutating repository integration scripts, migrations, live provider calls, payments, destructive tests, or build steps that mutate output.
- Confidence is source-evidence confidence. “Requires Validation” is not claimed as a confirmed production defect.

Launch Gates / Risk Matrix

Priority	Launch blocker	Required decision
P1	Checkout has no atomic idempotency boundary.	Fix before launch
P1	Paymob callback does not verify transaction amount/currency/intention against local intent.	Fix before launch
P1	AI quotas are read-then-write and race under concurrency.	Fix before launch

P1	Paymob HMAC field order is explicitly unverified.	Sandbox certify before launch
P1	One serial daily cron does high-fan-out work for every workspace without durable retry queue.	Fix or prove safe scale

Full Findings

PR-001 — Duplicate payment-intent race can create two payable checkouts

Severity: P1 | **Confidence:** High | **Category:** Billing / concurrency

Exact location: `lib/billing.ts:148-215` ; `prisma/schema.prisma:815-844` .

Root cause: `startOrReuse` performs a non-locking `findFirst` for a pending equivalent intent, then separately creates the record and calls Paymob. The schema has no uniqueness/idempotency constraint for that equivalent checkout key.

Failure scenario: double-click, retry, or parallel request both see no row and create Paymob intentions. Both checkout URLs are payable.

Customer / financial impact: double charge, refund/support cost, subscription confusion and loss of trust.

Evidence: static flow lines 163-185; endpoint rate limiting cannot serialize concurrent requests.

Recommended fix: database-enforced idempotency key/partial unique constraint, atomic compare-and-create transaction, provider idempotency propagation, and concurrent checkout test.

PR-002 — Payment fulfillment lacks economic binding to the expected intent

Severity: P1 | **Confidence:** High | **Category:** Billing / data integrity

Exact location: `app/api/webhooks/paymob/route.ts:98-115` ; `lib/billing.ts:243-297` .

Root cause: after HMAC validation, fulfillment uses `extras.intentId` and transaction ID only. It does not compare received Paymob intention/order, `amount_cents` , currency, or user ID with stored `PaymentIntent` , despite retaining those fields.

Failure scenario: provider/configuration/order-mapping mismatch activates wrong plan or credits for an underpaid or unrelated success transaction.

Impact: underpayment, wrong entitlement and difficult reconciliation.

Recommended fix: validate immutable economic fields before transition; uniquely constrain transaction ID; retain rejected mismatches.

PR-003 — AI quota controls are bypassable by parallel requests

Severity: P1 | **Confidence:** High | **Category:** AI FinOps / race condition

Exact location: `lib/aiRateLimit.ts`, including chat, refresh, image-quality and site-scan quota consumers; `app/api/ai/chat/route.ts:60-81`.

Root cause: counters are read, checked in memory, then written as absolute `count + 1`, with no conditional update, transaction lock or reservation ledger.

Failure scenario / impact: simultaneous requests at a quota boundary all receive permission and call providers; writes may collapse, allowing spend beyond sold quota.

Recommended fix: conditional atomic update with predicates or transactional reservations; provider spend cap; parallel test.

PR-004 — Paymob HMAC implementation is knowingly unvalidated

Severity: P1 | **Confidence:** High | **Category:** Payments / availability | **Validation Required:** Paymob sandbox

Exact location: `app/api/webhooks/paymob/route.ts:11-24, 50-61`.

Root cause/evidence: source comments say the HMAC field order is inferred rather than confirmed. The code fails closed.

Failure scenario / impact: valid production callbacks return 401; customers pay but access/credits remain pending, triggering support/refunds.

Recommended fix: certify success, failure, duplicate, refund, void and currency callbacks in sandbox; archive signed fixtures; use provider canonical order.

PR-005 — All-workspace sync is a serial, high-fan-out daily job without durable retries

Severity: P1 | **Confidence:** High | **Category:** Reliability / scalability

Exact location: `vercel.json`; `app/api/cron/sync-google-ads/route.ts`.

Root cause: one daily cron loops workspaces serially and invokes dozens of platform sync, diagnostics, AI, automation, notification and usage operations per workspace. Failures are recorded but not durably queued/retried.

Failure scenario / impact: at growth or elevated provider latency, invocation timeout leaves later workspaces stale; decisions/alerts use stale data and transient failures wait for the next daily run.

Recommended fix: per-workspace/platform idempotent queue with leases, bounded concurrency, retries and freshness SLO; prove completion under launch-scale load.

PR-006 — Provider/internal errors are returned directly during real ad actions

Severity: P2 | **Confidence:** High | **Category:** Security / UX

Exact location: `app/api/action-feed/[id]/apply/route.ts:44-51`; `app/api/creatives/decision/route.ts:46-56`; `lib/platformCampaignActions.ts`.

Root cause / impact: handlers serialize `err.message`, including Meta/TikTok response details, to browsers. This leaks operational detail and produces inconsistent, often Arabic-only recovery UX.

Recommended fix: server-side correlation ID/logging and typed localized client errors.

PR-007 — CSRF enforcement is inconsistent for authenticated mutations

Severity: P2 | **Confidence:** Medium | **Category:** Security / abuse

Exact location: examples: `app/api/action-feed/[id]/apply/route.ts`, `app/api/creatives/decision/route.ts`, `app/api/billing/checkout/route.ts`, `app/api/products/[id]/route.ts`.

Evidence: only 10 handlers call `verifyCsrfToken(req)`; many cookie-authenticated POST/PATCH/DELETE routes do not. `SameSite=Lax` mitigates conventional cross-site POST but is not a consistent defense policy.

Recommended fix: centralized CSRF/origin enforcement and high-impact route tests.

PR-008 — English UI has confirmed Arabic leakage and mixed direction

Severity: P2 | **Confidence:** High | **Category:** Localization / UX

Exact location/evidence: `scripts/checkArabicLeaks.mjs` reported 70 literals, including `app/components/ui/PageEmptyStates.tsx`, `app/login/LoginForm.tsx`, `app/onboarding/OnboardingFlow.tsx`, `app/signup/SignupForm.tsx`.

Impact: English users see Arabic at onboarding/empty states, impairing activation and trust. **Fix:** use locale-paired strings and block new leaks in CI.

PR-009 — User-facing error contract is not consistently enforced

Severity: P2 | **Confidence:** High | **Category:** UX / reliability

Exact location: `app/dashboard/settings/SettingsClient.tsx`, `app/components/WorkspaceSwitcher.tsx`, `app/dashboard/agent/AgentClient.tsx` and other direct `data.error` displays.

Failure scenario / fix: raw provider/validation/transport wording reaches customers and obscures recovery. Return typed codes and localize in client; retain diagnostics in logs only.

PR-010 — Critical integrations are statically implemented but not deployment-certified

Severity: P2 | **Confidence:** High | **Category:** Integrations / deployment | **Validation Required:** sandbox/staging

Evidence: `lib/envCheck.ts` only requires database and JWT secrets; `payment/OAuth/platform/backup/email/push` keys are optional. Static checks cannot prove provider credentials, permissions or callback configuration.

Impact/fix: live deployment may silently lack enabled capability. Implement enabled-feature preflight, sandbox certification and synthetic non-customer health checks.

PR-011 — Documentation is materially inconsistent with shipped scope

Severity: P3 | **Confidence:** High | **Category:** Documentation / operations

Exact location: `README.md` says 71 APIs and MCP is unbuilt; static inventory found 133 route handlers and active MCP OAuth/tools. **Impact:** incomplete threat model/runbooks. **Fix:** generated route/integration inventory in CI.

PR-012 — Tenant table indexing is uneven

Severity: P3 | **Confidence:** Medium | **Category:** Scalability / database

Exact location: `prisma/schema.prisma`. No detected `workspaceId` index on examples including `UploadedSheet`, `AutomationRule`, `LandingPageAudit`, `SiteScanResult`, `SharedReportLink` and `ConversionValueConfig`. **Impact:** potential scale bottleneck; validate with query plans/cardinality before indexing.

PR-013 — Critical-flow automated test evidence is incomplete

Severity: P3 | **Confidence:** High | **Category:** Testing

Evidence: static controls passed, but no conventional test script is visible in `package.json`. DB integration scripts intentionally mutate fixtures, so they were not run. **Fix:** isolated CI tests for checkout atomicity, callback reconciliation, quota concurrency, BOLA, ad-action confirmation and cron idempotency.

Top 20 Risks Ranked by Impact

#	Risk	Priority
1	Concurrent checkout creates two payable intents	P1
2	Wrong/underpaid payment activates entitlement	P1
3	Concurrent AI requests exceed sold quota/provider budget	P1

4	Paymob HMAC rejects valid callbacks	P1
5	Serial cron timeout creates stale customer data	P1
6	Provider/internal errors leak to customers	P2
7	Inconsistent CSRF on cookie-auth mutations	P2
8	English users see Arabic/mixed-direction UI	P2
9	Enabled integrations deploy without credentials/certification	P2
10	Raw errors cause failed recovery/stuck UX	P2
11	Ad writes are irreversible external financial actions	P2
12	Provider single points cause incomplete data	P2
13	Manual payment reconciliation required	P2
14	Data freshness is not self-healing	P2
15	Feature flags can mask broken integrations	P2
16	Docs understate attack/ops surface	P3
17	Tenant queries degrade at growth	P3
18	Critical regressions lack repeatable coverage	P3
19	Translation quality gate currently fails	P2
20	Support load from mixed-language/provider error UX	P2

Remediation Priorities

Must Fix Before Launch: PR-001, PR-002, PR-003, PR-004 sandbox validation, PR-005, and provider preflight from PR-010. Prevent raw provider errors on ad writes (PR-006).

Can Be Deferred with a dated owner: CSRF policy standardization, localization cleanup, documentation generation, query-plan-driven indexes, and test-suite maturation. These are not launch blockers only after the P1 gates have closed.

Scorecard

Area	/10	Assessment
Security	6	Strong auth/encryption/tenant baseline; CSRF and error exposure gaps.
Architecture	6	Clear modules; serial cron concentration.
Data Integrity	6	Dedupe/tenant patterns exist; payment binding/freshness need proof.
Billing	3	Checkout race and callback reconciliation risk.
AI Cost Control	3	Controls exist but lack atomic reservation.
Attribution	6	Thoughtful hashing/dedupe; provider proof needed.
Integrations	5	Broad code coverage, insufficient sandbox evidence.

Reliability	4	No durable retry queue for critical all-workspace job.
Scalability	4	Serial fan-out and uneven indexes.
UX/UI	6	System present; error/localization hurts trust.
Localization	4	70 confirmed Arabic leaks.
Deployment	5	Headers/config good; feature readiness preflight incomplete.
Code Quality	7	Defensive patterns but atomicity gaps in business-critical paths.
Documentation	4	Material route/MCP drift.
Testing	4	Useful static scripts; critical flow regression gaps.
Overall readiness	4	Not ready for paid launch.

Positive Controls Observed

- Central workspace ownership helper is used by the static checker, which passed.
- E-commerce webhook auth and platform usage-counting checks passed.
- Server-derived prices and an atomic pending-to-paid state transition prevent duplicate fulfillment of one intent.
- HTTP-only secure production session cookies, pinned JWT algorithm, session invalidation and suspended-user checks.
- Encrypted OAuth/platform tokens and SSRF-aware fetching for site scans.
- Translation key parity/coverage passed; offline production dependency audit reported zero known vulnerabilities.

Final CTO Verdict

NOT READY. Do not accept paying customers until payment intent creation and payment-to-entitlement verification are atomic and economically bound, AI quota consumption is atomic, Paymob callbacks are sandbox-certified, and the scheduled sync has a measured resiliency/scalability plan. No code changes were made during this audit.

Evidence source: checked-out codebase at revision 2803620f61a99f01800ccc2116dd78e23cd1de10; source review; safe scripts `checkTranslations`, `checkTranslationCoverage`, `checkArabicLeaks`, `checkBilingualFields`, `checkWebhookAuth`, `checkPlatformCallsCounted`, `checkWorkspaceAccess`; TypeScript no-emit; offline npm audit. Generated 19 August 2026.